

• **Un test d'intrusion** ou en anglais penetration testing est un processus autorisé, planifié et systématique d'utilisation de vulnérabilités connues pour tenter d'accéder à un système, un réseau ou à des ressources d'une application.

• **L'objectif d'un test d'intrusion** est d'identifier les vulnérabilités du système et de proposer des correctifs avant que ces vulnérabilités ne soient découvertes et exploitées par des pirates informatiques ou des cybercriminels.

Différence entre :

Test d'intrusion : • Un cadre bien défini • Suit des méthodologies de test • Se base sur des standards de gouvernance • Se réalise sur une période donnée

Hacking : • Objectif de compromission • Pas de cadre défini • Pas de méthodologie • Recherche opportuniste des vulnérabilités • N'est pas cadré dans le temps.

Ethical Hacking : • Objectif bienveillant • Pas de cadre défini • Pas de méthodologie • Recherche opportuniste des vulnérabilités • N'est pas cadré dans le temps.

Le test d'intrusion peut être réalisé selon 3 approches :

✓ **Black box :** le test d'intrusion en boîte noire est réalisé dans les conditions les plus proches d'une attaque externe réalisée par un attaquant distant inconnu.

✓ **White box :** le test d'intrusion en boîte Blanche EST réalisé avec le maximum d'informations partagées avec les pentesters avant l'audit.

✓ **Grey box :** Le test d'intrusion en boîte grise est réalisé avec le minimum d'informations partagées avec les pentesters avant l'audit.

OSSTMM (The Open Source Security Testing Methodology Manual) :

permet de tester la sécurité opérationnelle de 5 canaux, afin que les organisations puissent comprendre toute l'étendue de leur sécurité et déterminer dans quelle mesure leurs processus de sécurité fonctionnent réellement.

1. Sécurité humaine, 2.Sécurité physique, 3.Communications sans fil, 4.Télécommunications, 5.Réseaux de données.

Les quatre modules définis par

L'OSSTMM sont :

Phase I : Réglementaire :

✓ Examen de la posture ✓ Logistique
✓ Vérification de la détection active.

Phase II : Définitions :

✓ Audit de visibilité ✓ Vérification d'accès ✓ Vérification de la confiance
✓ Vérification des contrôles.

Phase III : Phase d'information :

✓ Vérification des processus
✓ Vérification de la configuration
✓ Validation de la propriété

Phase IV : Phase de test

des commandes interactives :

✓ Vérification de quarantaine ✓
Audit des privilèges ✓ Validation de la capacité de survie ✓ Examen des alertes et des journaux.

L'OSSTMM se concentre sur les éléments qui doivent être testés, ce qu'il faut faire avant, pendant et après un test de sécurité, et comment mesurer les résultats.

La méthodologie PTES (penetration testing execution standard)

se compose de sept (7) sections principales. Celles-ci couvrent tout ce qui concerne un test d'intrusion - de la communication initiale et du raisonnement derrière un test d'intrusion

Les étapes :

1- Interactions pré-engagement : Les réunions préalables à l'engagement avec le client permettent de discuter du degré de couverture du test d'intrusion qui sera réalisé.

2- La collecte de renseignements :

La phase de collecte de renseignements consiste à récupérer n'importe quelle information à propos de l'entreprise testée.

3-Modélisation des menaces : La modélisation des menaces exploite les informations recueillies lors de la collecte de renseignements.

4-Analyse des vulnérabilités :

Après avoir identifié le type d'attaque le plus efficace à mener contre la cible, il faut maintenant savoir comment y accéder.

5-Exploitation : La plupart du temps, la phase d'exploitation utilise l'attaque par brut force.

6 -Post-exploitation : La phase postérieure à l'exploitation est une phase critique dans un test d'intrusion.

7-Rapports :

L'OWASP (Open Web Application

Security Project) est une organisation internationale à but non lucratif qui vise à améliorer la sécurité des logiciels. **Sa principale mission** consiste à garantir que la sécurité du logiciel est visible et à fournir les informations et les outils qui permettent d'améliorer la sécurité des applications dans son ensemble.

Parmi les projets OWASP les plus connus : ✓ OWASP TOP 10

✓ OWASP ZAP

✓ OWASP Web security testing guide

La méthodologie OWASP WSTG :

se base sur plusieurs projets OWASP, donne des principes généraux sur la manière et le mindset avec lesquels aborder les tests d'intrusion applicative.

Les phases :

-La collecte d'informations
-Gestion de la configuration et du déploiement

-Gestion des identités

-Autorisation

-Authentication

-Gestion des sessions

-La validation des entrées

-La gestion des erreurs

-Cryptographie

-Logique métier

-Test côté client

La reconnaissance passive

(collecte passive d'informations) ou encore OSINT (Open Source Intelligence) est un processus de collecte d'informations disponibles publiquement concernant une cible, sans aucune interaction directe avec elle.

Le but de la reconnaissance passive

est de recueillir des informations qui clarifient et/ou élargissent la surface d'attaque sur une cible donnée.

La reconnaissance passive existe beaucoup de ressources et d'outils disponibles pour la collecte

d'informations : ✓ Les moteurs de recherche ✓ Les réseaux sociaux ✓ Les sites spécialisés dans la collecte d'informations publiques sur les organisations ✓ Les outils OSINT ✓ Les méthodes d'ingénierie sociale

Kali Linux est une distribution Linux spécialisée destinée aux professionnels de la sécurité. En tant que tel, il contient plusieurs fonctionnalités non standard. L'installation par défaut de Kali est livrée avec plusieurs services préinstallés, tels que SSH, HTTPMy

Le service SSH est basé sur TCP et écoute par défaut sur le port 22. Pour démarrer le service SSH dans Kali, nous exécutons `systemctl` avec l'option `start` suivie du nom du service

Le service Apache HTTP est souvent utilisé lors d'un test d'intrusion, soit pour héberger un site, soit pour fournir une source de téléchargement de fichiers sur une machine cible. Le service HTTP est basé sur TCP et écoute par défaut sur le port 80.

Les informations concernant les packages APT sont mises en cache localement pour accélérer tout type d'opération qui implique d'interroger la base de données APT.

Apt update : est toujours recommandé de mettre à jour la liste des packages disponibles, y compris les informations relatives à leurs versions, leurs descriptions.

Apt upgrade : Une fois la base de données APT mise à jour, nous pouvons mettre à niveau les packages installés et le système principal vers les dernières versions à l'aide de la commande `apt upgrade`.

apt-cache search : La commande de recherche `apt-cache` affiche une grande partie des informations stockées dans le cache de la base de données interne des paquets.

Apt show : Certains résultats ne contiennent pas forcément le mot-clé `python2`.

Apt remove -purge : La commande `apt remove -purge` supprime complètement les packages de Kali.

Parrot OS est une alternative de Kali Linux qui commence à être utilisée pour les tests d'intrusion. Parrot OS est une distribution aussi basée sur Debian qui se concentre principalement sur tout ce qui concerne la sécurité informatique.

recon-ng est un framework basé sur des modules pour la collecte d'informations sur le Web. `recon-ng` affiche les résultats d'un module au terminal mais il les stocke également dans une base de données.

TheHarvester est un autre outil OSINT pour la reconnaissance. Il utilise plusieurs sources d'information pour collecter des informations et nous aider à déterminer le périmètre de l'entreprise. **TheHarvester** récupère les e-mails, les sous-domaines, les IPs et les URLs

SpiderFoot est un outil OSINT de reconnaissance qui interroge automatiquement plus de 100 sources de données publiques pour collecter des informations sur les adresses IP, les noms de domaine, les adresses e-mail, les noms et plus encore.

L'OSINT framework contient des outils de collecte d'informations et des sites Web dans un emplacement central. Certains outils répertoriés dans ce framework couvrent plus de disciplines que la cybersécurité.

Maltego est un outil d'exploration de données très puissant qui offre une combinaison infinie d'outils et de stratégies de collecte d'informations.

La reconnaissance active : fait référence à la collecte d'informations sur le système à des fins de piratage ou de tests de pénétration du système.

Les classes des ports

Ports Ports connus 0-1023

Ports enregistrés 1024-49151

Ports privés 49152-65535

Les ports les plus connus/utilisés

Num port	Service
20	FTP
22/23	Ssh/telnet
25	Smtp
53	Dns
80/443	http/https
161	snmp
88	kerberos

Nmap est la norme de l'industrie des scanners. C'est un outil extrêmement puissant, rendu encore plus puissant par son moteur de script qui peut être utilisé pour rechercher des vulnérabilités et, dans certains cas, même exécuter l'exploit directement.

• **Les 3 types de scans nmap basiques**

✓ TCP Connect Scans (-sT) ✓ SYN

"Half-open" Scans (-sS)

✓ UDP Scans (-sU)

• **D'autres types de scans existent :**

✓ TCP Null Scans (-sN) ✓ TCP FIN

Scans (-sF) ✓ TCP Xmas Scans (-sX)

Nessus est un scanner de vulnérabilité.

Il utilise des techniques similaires à Nmap pour trouver et signaler les vulnérabilités, qui sont ensuite présentées dans une interface graphique agréable à regarder.

Nessus est différent des autres scanners car il ne fait pas d'hypothèses lors de la numérisation, comme si l'application Web s'exécuterait sur le port 80 par exemple.

Nexpose est un scanner de Rapid7.

Rapid7 est la même société qui produit Metasploit et l'un des principaux avantages si vous êtes un utilisateur de Metasploit, est la façon dont Nexpose y intègre ses résultats. Nexpose peut être utilisé dans un environnement Linux/UNIX ou Windows.

SMB - Server Message Block Protocol - est un protocole de communication client-serveur utilisé pour partager l'accès aux fichiers, imprimantes, ports série et autres ressources sur un réseau.

Telnet est un protocole d'application qui vous permet, à l'aide d'un client telnet, de vous connecter et d'exécuter des commandes sur une machine distante hébergeant un serveur telnet.

File Transfer Protocol (FTP) est, comme son nom l'indique, un protocole utilisé pour permettre le transfert à distance de fichiers sur un réseau.

http/https utilisé et lancer des scans pour identifier des vulnérabilités d'une manière automatisée et générale, nous devons envisager d'utiliser des outils spécialisés d'évaluation d'applications Web pour énumérer plus d'informations sur la cible.

Les vulnérabilités peuvent être

utilisées pour: ✓ Récupérer de l'information ✓ Faire planter le système affecté ✓ Prendre complètement le contrôle du système affecté

Cobalt Strike est un logiciel commercial de simulation d'adversaires utilisé surtout par des équipes de red team et lors des tests d'intrusion longs et poussés, mais également volé et activement utilisé par un large éventail d'acteurs malveillants, des opérateurs de ransomwares aux menaces persistantes avancées (APT) axées sur l'espionnage. **Cobalt Strike** est l'application de commande et de contrôle (C2) elle-même. Celui-ci comporte deux composants principaux : le team-server et le client.

BEACON est le nom du payload de malware par défaut de Cobalt Strike utilisée pour créer une connexion au serveur de l'équipe. Il existe deux types de BEACON : ✓ Le Stager est un payload BEACON facultative ✓ Le backdoor complet.

Empire est un serveur C2 ou Command and Control créé par BC-Security, utilisé pour déployer des agents sur un appareil et exécuter des modules à distance.

Installer Empire :

1. cd /opt
2. Git clone <https://github.com/BC-SECURITY/Empire>
3. Cd /opt/Empire
4. ./setup/install.sh

Installer Starkiller:

1. cd /opt
2. Télécharger une version à jour de Starkiller du github de BC-Security: <https://github.com/BC-SECURITY/Starkiller/releases>
3. chmod +x starkiller-0.0.0.AplImage

Le framework Metasploit est un ensemble d'outils qui permettent la collecte d'informations, l'analyse, l'exploitation, le développement d'exploits, la postexploitation, etc. Bien que l'utilisation principale de Metasploit Framework se concentre sur le domaine des tests d'intrusion, il est également utile pour la recherche de vulnérabilités et le développement d'exploits.

✓ **Msfcconsole:** l'interface de ligne de commande principale.

✓ **Modules:** modules de support tels que les exploits, les scanners, les charges utiles

✓ **Outils:** outils autonomes qui faciliteront la recherche de vulnérabilités,

✓ **Searsh:** rechercher des exploits

✓ **info:** obtenir plus d'informations sur l'exploit

✓ **exploit:** lancer l'exploit

✓ **Show payloads:** configurer les autres commandes que nous pouvons utiliser avec cet exploit spécifique.

Un buffer overflow (BO) est une faute d'implémentation consistant à déborder de la mémoire allouée pour une opération. La plupart des BO dues au développeur ne vérifiant pas les tailles mémoires avant d'effectuer des opérations de copie. Les BO sont très courants dans les programmes écrits en langages dits «bas niveaux» comme le C ou C++

• Pour exploiter une vulnérabilité buffer overflow, il est indispensable de comprendre l'anatomie de la pile mémoire (stack)

• Lorsque nous examinons la pile de mémoire, nous trouvons 4 composants principaux :

1. Pointeur de pile étendu (ESP)
2. Espace tampon (Buffer space)
3. Pointeur de base étendu (EBP)
4. Pointeur d'instruction étendu (EIP) / adresse de retour

post-exploitation permet aussi une énumération plus approfondie du système cible avec **des outils comme powerview et bloodhound**, la collecte des hashes et la réalisation d'autres attaques par exemple sur l'AD avec mimikatz, la collecte d'informations de base à l'aide des outils et des journaux. Le maintien de l'accès peut se réaliser avec le module metasploit de persistance et la création d'une porte dérobée (backdoor) dans la machine pour obtenir un shell meterpreter instantané au cas où le système est arrêté ou réinitialisé.

L'élévation des privilèges est cruciale car elle permet d'obtenir des niveaux d'accès d'administrateur système et d'effectuer **des actions:** ✓ Réinitialiser les mots de passe ✓ Contourner les contrôles d'accès pour compromettre les données protégées ✓ Modification des configurations logicielles ✓ Activer la persistance ✓ Modifier le privilège des utilisateurs existants (ou nouveaux) ✓ Exécuter n'importe quelle commande administrative

Porte dérobée ou Backdoor en anglais

est une méthode qui permet à un pentester/hacker d'accéder à distance à un système cible sans exploiter une vulnérabilité du système en question. Il doit fonctionner en arrière-plan et n'apparaît pas dans les logiciels en cours d'utilisation. **Un backdoor** peut être utilisé pour espionner un utilisateur, gérer ses fichiers, installer des logiciels supplémentaires ou des malwares, surveiller l'ensemble du système du PC et attaquer d'autres hôtes. • Souvent, le backdoor a également d'autres fonctions malveillantes, tels que l'enregistrement des frappes de clavier, la capture d'écran, les infections diverses et le chiffrement de fichiers.